

Secure System Architecture

Final Exam — Predicted Questions & Model Answers

Lectures 4 · 5 · 6 · 7 | Ordered by Priority

MUST KNOW — Zero MCQ coverage

HIGH — Partially tested

MEDIUM — Lightly tested

Q13

Priority: MUST KNOW

What is a DMZ? Describe its architecture and explain why it is important.

Answer:

Definition: A DMZ (Demilitarized Zone) is a separate network zone positioned between the untrusted Internet and the trusted internal network. It hosts public-facing services while preventing direct exposure of internal systems.

Architecture:

Zone	Component	Role
Internet (Untrusted)	External Firewall	Filters inbound traffic from internet
DMZ	Web / Mail / DNS Servers, Reverse Proxies	Public-facing services
Internal Firewall	Second Firewall	Separates DMZ from internal network
Internal Network	App Servers, Databases	Protected core systems

Why it is important:

Reason	Explanation
Protects internal systems	Internal network is never directly exposed to the internet
Reduces attack surface	Attackers reach DMZ first, not core systems
Controls traffic	Strict firewall rules enforced on both sides
Enables secure public access	Users reach web services without breaching the internal network

Without DMZ: internal systems directly exposed → higher breach risk, no isolation between public and private services.

Q12

Priority: MUST KNOW

List and describe the 5 types of VPN with the use case for each.

Answer:

Definition: A VPN (Virtual Private Network) creates a secure, encrypted tunnel between a device and a network, hiding the IP address and protecting data in transit.

Type	Use Case
Remote Access	Single user connects securely to the company network over the internet
Site-to-Site	Two entire networks connected via a permanent encrypted tunnel (e.g. HQ ↔ Branch)
SSL / TLS	Browser-based VPN using HTTPS — works on any device without a VPN client
Mobile	Maintains connection when switching between Wi-Fi and mobile data

Type	Use Case
Cloud	VPN hosted in the cloud — scalable, no physical hardware required

Q10

Priority: MUST KNOW

Describe the 4 Core Principles of Secure Network Architecture. For each, explain the concept and give an implementation example.

Answer:

Principle	Concept	Implementation
Least Privilege	Users and systems get only the minimum access needed to perform their task	RBAC, Just-In-Time (JIT) access, access reviews & auditing
Defense in Depth	Multiple security layers — if one layer fails, others still protect the system	Firewall → IDS/IPS → Endpoint Security → Encryption
Zero Trust	No user or system is trusted by default, even inside the network. Never trust, always verify.	MFA, identity-based access, device validation, continuous verification
Segmentation	Network divided into isolated zones to prevent lateral movement by attackers	VLANs, subnetting, micro-segmentation

Q9

Priority: MUST KNOW

What are the 4 risk response decisions? When is each used?

Answer:

Decision	When to Use	Example
Mitigate	Risk is significant — apply controls to reduce it	Install a firewall to reduce network attack risk
Transfer	Risk is too costly to handle alone	Buy cyber insurance
Accept	Risk is low enough that cost of fixing exceeds impact	Minor UI vulnerability with no sensitive data exposure
Avoid	Eliminate the activity that causes the risk entirely	Stop using an insecure legacy system

Risk = Likelihood x Impact

Q5

Priority: MUST KNOW

List the 3 types of Business Requirements and the 3 types of Security Controls. Explain the mapping process between them.

Answer:

Business Requirement Types:

Type	Definition	Example
Regulatory	Legal and compliance obligations	GDPR, PCI-DSS, ISO 27001
Operational	Business continuity needs	System availability, uptime SLAs
Strategic	Long-term business growth goals	Digital transformation, cloud migration

Security Control Types:

Type	Definition	Example
Technical	Technology-based safeguards	Firewalls, encryption, IDS/IPS

Type	Definition	Example
Administrative	Policy and process-based controls	Security policies, training, procedures
Physical	Physical access restrictions	Keycards, CCTV, locked server racks

Mapping Process: 1. Identify business requirement → 2. Identify the risk → 3. Select appropriate control → 4. Validate effectiveness

Q8

Priority: MUST KNOW

Describe the DREAD model. List each factor, its meaning, and explain how the final risk score is calculated. Give a scored example.

Answer:

Definition: DREAD is a Microsoft risk prioritization framework used after STRIDE identifies threats. It answers: "Which vulnerabilities should we fix first?"

Letter	Factor	Question Asked
D	Damage Potential	How severe is the impact if the attack succeeds?
R	Reproducibility	How easily can the attack be repeated?
E	Exploitability	How easy is it to launch the attack?
A	Affected Users	How many users would be impacted?
D	Discoverability	How easy is it to find the vulnerability?

Scoring Formula: DREAD Score = (D + R + E + A + D) / 5 (scale: 1–10 per factor)

Example — Login Vulnerability:

Factor	Score
Damage	9
Reproducibility	8
Exploitability	7
Affected Users	9
Discoverability	8
Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Final Score' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='Final Score', textColor=Color(.101961,.101961,.180392,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph	Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': '(9+8+7+9+8) / 5 = 8.2 → HIGH RISK' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='(9+8+7+9+8) / 5 = 8.2 → HIGH RISK', textColor=Color(.101961,.101961,.180392,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph

Q7**Priority: HIGH**

Describe the STRIDE model. List each category, its meaning, and give one example.

Answer:

Definition: STRIDE is a Microsoft framework to identify security threats in software systems. Used in system design, secure software development, and risk analysis.

Letter	Threat	Meaning	Example
S	Spoofing	Identity impersonation	Using fake credentials to log in
T	Tampering	Unauthorized data modification	Modifying session tokens
R	Repudiation	Denying performed actions	User denies placing an order
I	Information Disclosure	Exposing sensitive data	Leaking a database via SQL injection
D	Denial of Service	Making systems unavailable	Overloading a server with requests
E	Elevation of Privilege	Gaining unauthorized access level	Normal user accessing admin functions

Q1**Priority: HIGH**

List and describe the 4 phases of the NIST Incident Response Lifecycle, including the key activities of each phase.

Answer:

Phase	Core Action	Key Activities
1. Preparation	Build readiness before incidents	Create IR Plan, train SOC team, deploy SIEM/IDS/EDR, maintain asset inventory, run tabletop exercises
2. Detection & Analysis	Identify and validate incidents	Validate alerts, determine scope & incident type, assign severity, document IoCs
3. Containment → Eradication → Recovery	Stop, remove, restore	Contain: disconnect infected systems, block IPs. Eradicate: delete malware, patch, reset passwords. Recover: restore from backups, monitor for re-infection
4. Post-Incident Activity	Learn and improve	Lessons learned meeting, root cause analysis, update playbooks, train staff

Q4**Priority: HIGH**

List and describe the 5 phases of the Security Architecture Development Lifecycle, including the output of each phase.

Answer:

Phase	Key Activities	Output
1. Initiation	Define scope, identify stakeholders, understand business goals	Security vision + scope document
2. Assessment	Identify assets, analyze risks, perform gap analysis	Risk report, current posture evaluation
3. Design	Define controls, select architecture patterns, align with frameworks (NIST, SABSA)	Security architecture blueprint
4. Implementation	Deploy firewalls, IAM, monitoring tools, train users	Operational security controls
5. Monitoring & Improvement	Continuous monitoring, incident response, performance measurement	KPIs, updated controls

Q2

Priority: HIGH

List the 5 Core Functions of the NIST Cybersecurity Framework (CSF) and explain the purpose and activities of each.

Answer:

Function	Purpose	Key Activities
Identify	Understand the org and its risks	Asset management, risk assessment, governance and policies
Protect	Prevent or reduce attack impact	Access control, encryption, security awareness training, maintenance
Detect	Discover cybersecurity events quickly	Continuous monitoring, log analysis, anomaly detection
Respond	Take action after detecting an incident	IR planning, communication, root cause analysis, containment
Recover	Restore normal operations	Backup and restore, recovery planning, business continuity

Memory aid: Know it → Guard it → Spot it → Handle it → Fix it

Q6

Priority: MEDIUM

What are the 5 Maturity Model levels? Why are maturity models used?

Answer:

Level	Name	Meaning
1	Initial	Ad-hoc, unpredictable, no formal process
2	Managed	Basic processes exist but inconsistent across teams
3	Defined	Standardized and documented processes across the organization
4	Quantitatively Managed	Processes measured and controlled using metrics
5	Optimized	Continuous improvement embedded in the organization

Why use maturity models: Identify weaknesses, track progress over time, benchmark against industry standards.

Q11

Priority: MEDIUM

Compare the 3 types of Network Segmentation (VLAN, Subnetting, Micro-segmentation) in terms of layer, method, and use case.

Answer:

Type	Layer	Method	Use Case
VLAN	Layer 2 (Data Link)	Logical grouping via switches	Separate HR from Finance on same physical network
Subnetting	Layer 3 (Network)	IP address-based division via routers	Routing control and traffic management between departments
Micro-segmentation	Workload/App level	Fine-grained policies per workload or container	Inside data centers and cloud — core component of Zero Trust

Key benefit of all segmentation: prevents lateral movement — attacker cannot move freely across the network after initial breach.

Q3

Priority: MEDIUM

What are Common Indicators of Compromise (IoCs)? List at least 5.

Answer:

Definition: IoCs are signs that a system may have been compromised or is under attack. Detected during the Detection & Analysis phase of NIST IR.

#	Indicator of Compromise	What it may indicate
1	Suspicious login attempts	Brute force or credential stuffing attack
2	Large unexpected outbound traffic	Data exfiltration or C2 communication
3	Unrecognized processes running	Malware or backdoor execution
4	Connections to known malicious IPs	Active C2 communication or botnet
5	File encryption activity	Ransomware in progress